

Kavramlar

mshta.exe → Microsoft HTML Application Host. Windows'un içinde gelen, meşru/imzalı bir sistem programı. Görevi .hta uzantılı dosyaları veya bir URL'den gelen HTML/JScript/VBScript içeriğini çalıştırmak. Kendisi zararlı değil, ama script çalıştırabildiği ve "zaten Windows'un parçası" olduğu için saldırganlar tarafından fark edilmeden kod çalıştırmak amacıyla kötüye kullanılır.

LOLBin (Living-off-the-Land Binary) → Bilgisayarda zaten yüklü, meşru, imzalı sistem araçlarının saldırı amacıyla kötüye kullanılması. mshta.exe, certutil, rundll32, regsvr32, bitsadmin bu kategoriye örnek. Ayırt edici olan aracın kendisi değil, nasıl ve kim tarafından çağrıldığı.

lsass.exe (Local Security Authority Subsystem Service) → Windows'un, oturum açmış kullanıcıların kimlik bilgilerini (şifre hash'leri, Kerberos ticketları vb.) geçici olarak bellekte tuttuğu sistem süreci. Bir process'in lsass.exe'ye erişmesi, genelde kimlik bilgisi hırsızlığı (credential dumping) girişimidir.

sekurlsa::logonpasswords → Mimikatz adlı bilinen bir credential-dumping aracının komut sözdizimi. Bu ifadenin bir process'in CommandLine alanında geçmesi, güçlü bir Mimikatz kullanım göstergesidir.

.docm → Makro (otomatik çalışabilen gömülü kod) içerebilen Word dosya uzantısı. Normal .docx'ten farkı, dosya açıldığında kullanıcı fark etmeden kod çalıştırabilmesidir. Phishing/kötücül ek saldırılarında sık kullanılan bir formattır.

DNS tünelleme (DNS tunneling) → Verinin, bir DNS sorgusunun subdomain kısmına kodlanarak gönderilmesi yöntemi. Firewall'lar genelde DNS trafiğini tehlikesiz sayıp engellemediği için, saldırganlar veri sızdırmak (exfiltration) için bu kanalı kullanır.

Tipik imza: rastgele/anlamsız görünen uzun subdomain + TXT tipi sorgu + NXDOMAIN cevabı (domain gerçekte yok, ama sorunun içeriği zaten karşı tarafa ulaşmıştır).

Exfiltration → Kurumun içindeki verinin izinsiz şekilde dışarı çıkarılması.

OBSERVED / INFERRED / UNKNOWN (Kanıt sınıflandırma kuralı) :

- OBSERVED: logda doğrudan görülen
- INFERRED: gözlemden çıkarılan mantıklı sonuç, ama henüz doğrudan kanıtlanmamış
- UNKNOWN: veriden çıkmıyor, hangi veri çözerdi belli

Sorgular ve Bulgular

Firewall

Kullanılan filtre:

index=case2 sourcetype=case2:firewall src=192.168.20.45 action=allow

| stats count, sum(bytes_out), sum(bytes_in), earliest(_time), latest(_time) by dst

| convert ctime(earliest(_time)) ctime(latest(_time))

| sort -count

Not: convert ctime(...) epoch zaman damgasını okunabilir tarih/saate çeviriyor.

Neden önce firewall'a bakıldı: Ticket "olağandışı giden trafik" diyordu. Elimizdeki 6 kaynaktan ağ trafiğine doğrudan bakabilecek olan firewall (DNS de var ama o sadece isim çözümlemesini kaydeder, gerçek bağlantıyı değil). Yani ilk adım alarmanın kendisini doğrulamaktı →ticket'ın söylediği doğru bir tespit mi diye.

Bulunan kayıtlar:

New Search

Save As Create Table View Close

index=case2 sourcetype=case2:firewall src=192.168.20.45 action=allow
| stats count, sum(bytes_out) as total_bytes_out, sum(bytes_in) as total_bytes_in, earliest(_time)
as first_seen, latest(_time) as last_seen by dst
| convert ctime(first_seen) ctime(last_seen)
| sort -count

Time range: All time

37 events (before 8/27/26 8:28:30.000 AM) No Event Sampling Job II

Events Patterns Statistics (6) Visualization

Show: 20 Per Page Format Preview: On

dst	count	total_bytes_out	total_bytes_in	first_seen	last_seen
45.137.21.88	32	19405	53497	09/14/2026 09:41:24	09/14/2026 11:25:10
104.16.85.20	1	1500	88000	09/14/2026 09:33:12	09/14/2026 09:33:12
142.250.187.4	1	900	30000	09/14/2026 09:10:03	09/14/2026 09:10:03
185.220.101.44	1	503316480	5120	09/14/2026 11:20:37	09/14/2026 11:20:37
23.55.11.10	1	1200	45000	09/14/2026 08:30:16	09/14/2026 08:30:16
52.96.42.10	1	2200	60000	09/14/2026 10:50:00	09/14/2026 10:50:00

Sonraki soru: Hedef bilinen bir IP mi, değil mi? Bu bağlantıyı hangi process açıyor? → DNS dosyasına bakmak gerekiyor.

DNS

Bulunan kayıtlar:

- 14.09.2026 10:15:44 — query: cdn.jsdelivr.net, A response: 104.16.85.20

- 14.09.2026 10:09:35 — query: static-cdn-analytics.com, A response: 45.137.21.88
- 14.09.2026 10:05:30 — query: ecc487c2e0...6283.static-cdn-analytics.com, TXT response: NXDOMAIN

New Search

Save As Create Table View Clo

index=case2 sourcetype=case2:dns "static-cdn-analytics.com"

Time range: All time

33 events (before 8/27/26 11:18:43.000 AM) No Event Sampling

Job

Events Patterns Statistics (33) Visualization

Show: 20 Per Page Format Preview: On

_time	_raw
2026-09-14 09:41:15	2026-09-14T09:41:15 dns-resolver query: client 192.168.20.45#51244 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:42:05	2026-09-14T09:42:05 dns-resolver query: client 192.168.20.45#51245 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:43:08	2026-09-14T09:43:08 dns-resolver query: client 192.168.20.45#51246 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:44:11	2026-09-14T09:44:11 dns-resolver query: client 192.168.20.45#51247 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:45:11	2026-09-14T09:45:11 dns-resolver query: client 192.168.20.45#51248 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:46:14	2026-09-14T09:46:14 dns-resolver query: client 192.168.20.45#51249 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:47:17	2026-09-14T09:47:17 dns-resolver query: client 192.168.20.45#51250 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:48:17	2026-09-14T09:48:17 dns-resolver query: client 192.168.20.45#51251 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:49:17	2026-09-14T09:49:17 dns-resolver query: client 192.168.20.45#51252 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:50:19	2026-09-14T09:50:19 dns-resolver query: client 192.168.20.45#51253 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:51:19	2026-09-14T09:51:19 dns-resolver query: client 192.168.20.45#51254 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:51:20	2026-09-14T09:51:20 dns-resolver query: client 192.168.20.45#52009 query: c6b3dc2bcc90b3e75ae86212d10663.static-cdn-analytics.com IN TXT response: NXDOMAIN
2026-09-14 09:52:19	2026-09-14T09:52:19 dns-resolver query: client 192.168.20.45#51255 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:53:19	2026-09-14T09:53:19 dns-resolver query: client 192.168.20.45#51256 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:54:19	2026-09-14T09:54:19 dns-resolver query: client 192.168.20.45#51257 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:55:21	2026-09-14T09:55:21 dns-resolver query: client 192.168.20.45#51258 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:56:24	2026-09-14T09:56:24 dns-resolver query: client 192.168.20.45#51259 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:56:25	2026-09-14T09:56:25 dns-resolver query: client 192.168.20.45#52014 query: 0ad7196551fe0fb882415a26e814db.static-cdn-analytics.com IN TXT response: NXDOMAIN
2026-09-14 09:57:24	2026-09-14T09:57:24 dns-resolver query: client 192.168.20.45#51260 query: static-cdn-analytics.com IN A response: 45.137.21.88
2026-09-14 09:58:27	2026-09-14T09:58:27 dns-resolver query: client 192.168.20.45#51261 query: static-cdn-analytics.com IN A response: 45.137.21.88

Bulgu: 45.137.21.88 için firewall'da 32 kayıt görülmüştü. DNS'e bakınca bu IP'nin static-cdn-analytics.com diye bir isme çözüldüğü görüldü.

Kayıtlar incelendiğinde domain'in başına rastgele, anlamsız bir kod dizisi eklendiği görüldü. Diğerlerinde A response istenirken burada TXT istendiği ve NXDOMAIN ("böyle bir yer yok") cevabının geldiği görüldü.

rastgele kod + TXT soru + "yok" cevabı → DNS tünelleme (KRİTİK! Kesin değil)

Sysmon

Soru: Bu sorguları (firewall/DNS'te görülen) hangi process üretiyor? → sysmon'da bulunacak.

Bulunan kayıt:

>	9/14/26 9:41:24.000 AM	2026-09-14T09:41:24 FIN-WS03 Microsoft-Windows-Sysmon/Operational: EventID=3 Image="C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" DestinationIp=45.137.21.88 DestinationHostname=static-cdn-analytics.com DestinationPort=443 Protocol=tcp User="COMPANY\b.kaya" ProcessId=5012 host = FIN-WS03 source = Case2-sysmon.log sourcetype = case2:sysmon
---	---------------------------	--

Bulgu: DNS'te bulunan IP/port ile birebir eşleşme var. OBSERVED durumundayız artık. Bu bağlantıyı açan process → powershell.exe.

Senaryo (henüz kanıtlanmadı — INFERRED)

Sahte bir fatura e-postayla/dosyayla geldi (Fatura_2026_4471.docm). Kullanıcı (b.kaya) bunu açmış.

Dosya açılınca makro arka planda kendiliğinden çalıştı. Makro, Windows'un kendi aracını (mshta.exe) kullanarak internete çıktı. static-cdn-analytics.com adresinden dosya indirip çalıştırdı.

Muhtemelen bu indirilen şey, gerçek saldırı aracını devreye soktu (powershell.exe programı devreye girdi ve trafiği başlattı). Ayrıca muhtemelen ayrı bir program (svchost_update.exe/m.exe) çalıştı ve bilgisayarın hafızasındaki şifre/kimlik bilgilerini çalmaya çalıştı.

Şu Anki Kanıt Durumu

OBSERVED:

- FIN-WS03 → 45.137.21.88 (static-cdn-analytics.com), 32 bağlantı, düzenli aralık
- Aynı domain'e 4 adet hex-subdomain + TXT + NXDOMAIN sorgusu
- powershell.exe'nin bu IP'ye bağlandığı
- WINWORD.EXE → mshta.exe başlatma zinciri, mshta.exe'nin aynı domain'den dosya indirmesi
- Bir process'in lsass.exe'ye Mimikatz-benzeri sözdizimiyle eriştiği

INFERRED:

- Yukarıdaki adımların hepsinin tek bir zincir olduğu (PID/ParentProcessId ile teyit gerekiyor)
- TXT/NXDOMAIN sorgularının gerçekten DNS tünelleme (veri sızdırma) olduğu
- Kimlik bilgisi hırsızlığının başarılı olup olmadığı

UNKNOWN:

- case2:mail — fatura e-postası nasıl geldi, SPF/DKIM sonucu
- case2:winsecurity — 4698 (scheduled task), 4624 (logon) detayları
- case2:auth (app-db01) — olay başka bir sisteme sıçramış mı (lateral movement)
- 185.220.101.44'e giden 480 MB'lık transfer — henüz hiç incelenmedi